

23 MAR 2022

US\$ 625M

Ronin Bridge

— "Um PDF malicioso custou US\$625M"

VALIDATOR KEY COMPROMISE · CRITICAL

O maior hack de DeFi — atribuído ao grupo Lazarus (Coreia do Norte)

O QUE ACONTECEU

Ronin Network era a sidechain do [Axie Infinity](#), o maior jogo play-to-earn do mundo na época, com bilhões em TVL.

A bridge usava um modelo de **multisig 5/9** — precisava de 5 validadores assinando para autorizar retiradas.

O grupo [Lazarus](#) (APT norte-coreano) enviou um **PDF com oferta de emprego falsa** para engenheiros da Sky Mavis. O malware comprometeu [4 chaves](#) de validadores.

A 5ª chave veio da [Axie DAO](#), que tinha dado permissão temporária à Sky Mavis meses antes — e **nunca revogou**. O hack só foi descoberto [6 dias depois](#), quando um usuário tentou sacar.

CONTRATO VULNERÁVEL

```
bytes[] calldata  
a Sky Mavis + 1  
da Axie DAO // = 5 chaves comprometidas // = controle total } }
```

Lição

Segurança operacional é tão crítica quanto código. Diversifique validadores, revogue permissões temporárias, monitore on-chain.

COMO O ATAQUE FUNCIONOU

PASSO 1

Oferta de emprego falsa (LinkedIn) → PDF malicioso

**PASSO 2**

Malware compromete 4 validadores da Sky Mavis

**PASSO 3**

5ª chave: Axie DAO (permissão nunca revogada)

**PASSO 4**

5/9 validadores = threshold atingido

**PASSO 5**

Duas transações de saque:

173.600 ETH + 25,5M USDC

**RESULTADO**

Hack descoberto 6 DIAS depois

Atribuído ao grupo Lazarus (Coreia do Norte)

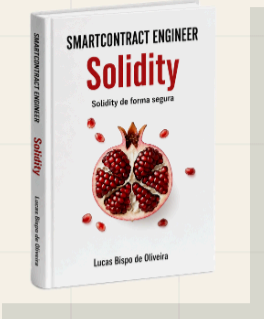
VERIFIQUE NA BLOCKCHAIN

Transação do Ataque

[etherscan.io/tx/0xc28fad...ec102](#)

Endereço do Atacante

[etherscan.io/address/0x098B7...2f96](#)



Solbook — Smartcontract Engineer

Segurança vai além do código — aprenda threat modeling completo